

บทที่ 4

ความปลอดภัยในการใช้งานเว็บเซิร์ฟเวอร์

Security หมายถึง เทคนิคในการที่จะมั่นใจได้ว่าข้อมูลที่ถูกเก็บอยู่ในคอมพิวเตอร์ หรือข้อมูลที่ถูกส่งผ่านระหว่างเครื่องคอมพิวเตอร์จะไม่ถูกเปลี่ยนแปลง โดยหลักการวัด security โดยทั่วไปนั้นส่วนใหญ่มักจะเกี่ยวกับการ พิสูจน์ข้อความ และการเข้ารหัส

การส่งข้อมูลใน e-commerce นั้นจะมี access point หลายจุดซึ่งผู้ประสงค์ร้ายจะสามารถดักจับ และเปลี่ยนแปลงข้อมูลได้ โดยเฉพาะยิ่งธุรกิจมีการกระจายตัวมากเท่าไรก็จะยิ่งเพิ่มโอกาสที่จะโดนโจมตีได้มากขึ้นจึงมีความต้องการซอฟต์แวร์ที่จะมาช่วยจัดการในด้านนี้

โดยในตอนต้นของบทนี้จะพูดถึงทฤษฎีที่เกี่ยวข้องกับการทำ Security ก่อน

4.1 Cipher Suite

Cipher Suite คือ กระบวนการเข้ารหัส (encryption) ของ SSL(Secure Socket Layer) ที่รวม key exchange algorithm, symmetric encryption และ secure hash algorithm เข้าด้วยกัน ตัวอย่างเช่น Cipher Suite ที่เรียกว่า RSA_WITH_RC4_128MD5 ใช้ RSA สำหรับ key exchange , RC4 ที่ใช้ 128-bit key ในการ encryption และ MD5 สำหรับการคำนวณแฮชไดเจสต์ (Message digest)

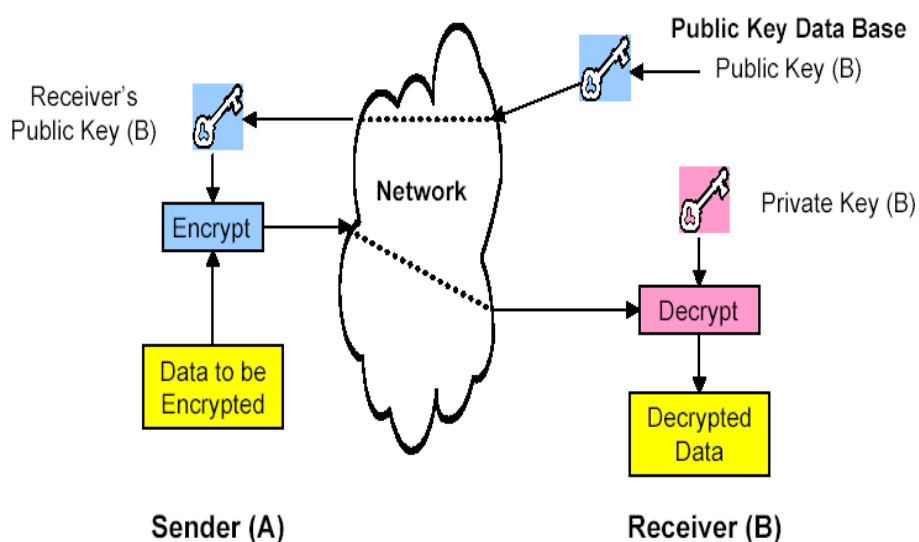
4.2 Public Key Algorithms

Public key(or asymmetric key)algorithms เป็นการใช้คีย์ 2 คีย์ที่แตกต่างกัน แต่มีความสัมพันธ์กันทางคณิตศาสตร์

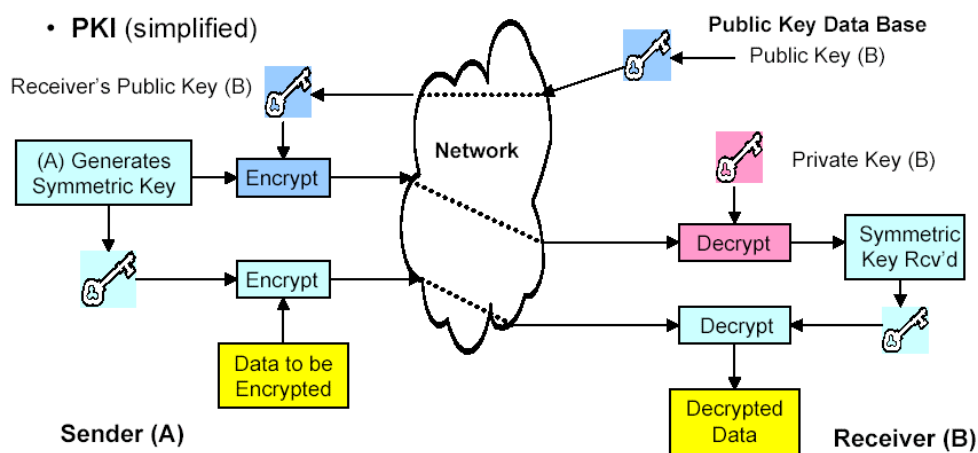
- คีย์สาธารณะ (A public key)(ที่ซึ่งถูกแจกจ่ายโดยทั่วไป) ใช้สำหรับการยืนยันลายมือชื่อดิจิตอล (digital signature) ว่าเป็นของผู้ส่งจริง หรือ ใช้ในการเปลี่ยนข้อมูลให้อยู่ในรูปที่ไม่สามารถเข้าใจได้
- คีย์ส่วนตัว(A private key)(ที่ซึ่งถูกเก็บเป็นความลับ) ใช้ในการสร้างลายมือชื่อดิจิตอลหรือเปลี่ยนข้อมูลที่ถูกส่งมาให้กลับอยู่ในรูปเดิม

4.3 Symmetric Key Algorithms

ใน symmetric key algorithms จะใช้คีย์เดียวกันทั้งการเข้ารหัสและการถอดรหัสเมสเสจโดยการใช้วิธีนี้จะเร็วกว่าแบบ public key cryptography ประมาณ 1,000 เท่า



รูปที่ 4-1 แสดงการใช้คีย์คู่ในการติดต่อ

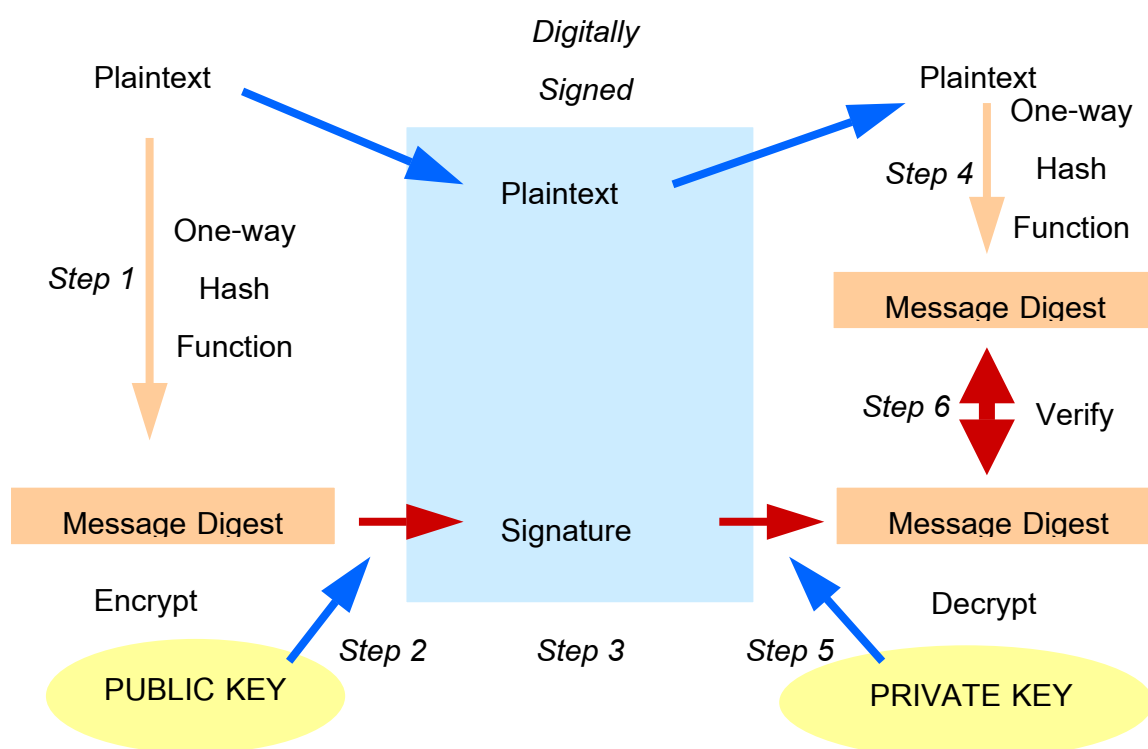


รูปที่ 4-2 แสดงการได้มาซึ่งคีย์เดียวในการติดต่อ

4.4 Message Digest Algorithms

สนับสนุนอัลกอริทึมเมสเสจไดเจสต์ แบบ MD5 และ SHA(Secure Hash Algorithm) ซึ่งเป็น one-way hash algorithm โดย one-way hash algorithm จะแปลงเมสเสจให้อยู่ในรูปแบบสตริงที่มีขนาดคงที่ซึ่งเรียกว่า เมสเสจไดเจสต์ (message digest) หรือ hash value

MD5 จะเป็น high-speed 128-bit hash ส่วน SHA จะมีความปลอดภัยมากกว่าโดยใช้ 160-bit hash แต่จะช้ากว่า MD5



รูปที่ 4-3 แสดงการนำ Message Digest ไปใช้ใน public-private key encryption

4.5 ลายมือชื่อดิจิตอล

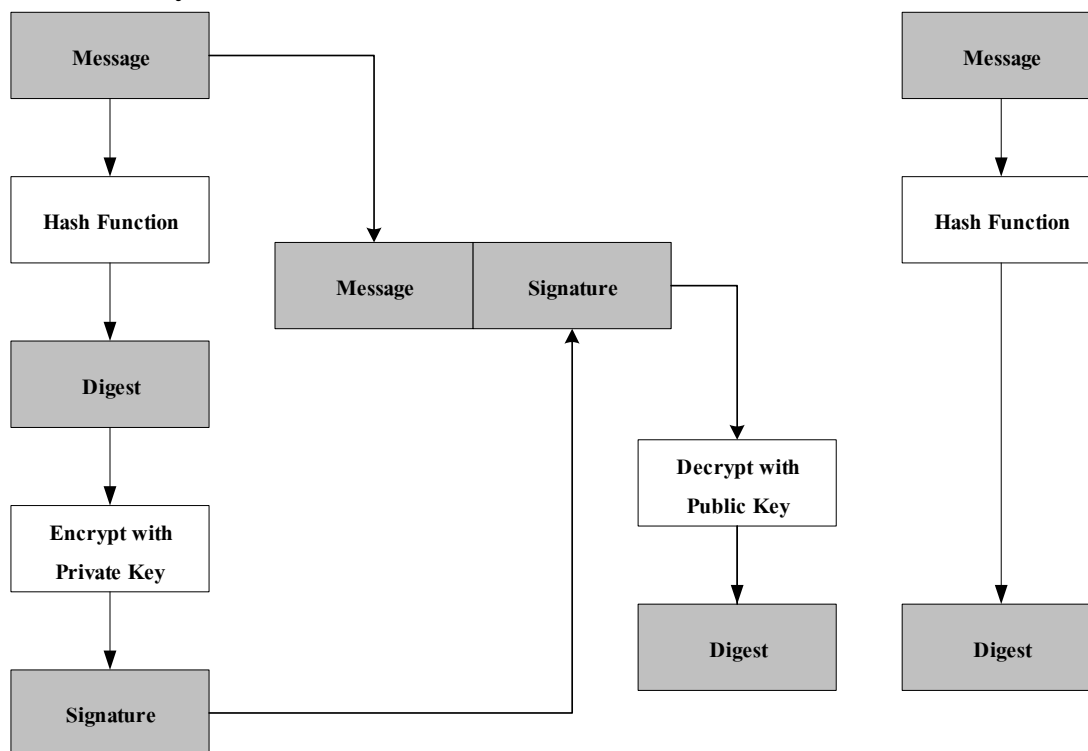
ลายมือชื่อดิจิตอลใช้เมื่อต้องการความมั่นใจในแหล่งที่มาของเอกสาร เหมือนลายมือชื่อซึ่งเฉพาะเจ้าของจริงที่สามารถคำนวณขึ้นได้ แต่ลายมือชื่อนี้สามารถพิสูจน์ได้ กล่าวคือบุคคลอื่นสามารถตรวจสอบได้ว่าลายมือชื่อนั้นมาจากผู้สร้างจริงๆ วิธีที่ใช้ในการทำลายมือชื่อดิจิตอลที่มีความปลอดภัยค่อนข้างสูงก็คือ การใช้ public-private key โดยเข้ารหัสค่าลายมือชื่อด้วยคีย์ส่วนตัว และคนอื่นสามารถใช้คีย์สาธารณะพิสูจน์ได้ว่าลายมือชื่อมาจากคีย์ส่วนตัวที่ตรงกัน

คุณสมบัติที่สำคัญของลายมือชื่อดิจิตอลที่สำคัญนั้นจะต้องประกอบด้วย 2 ประการคือ

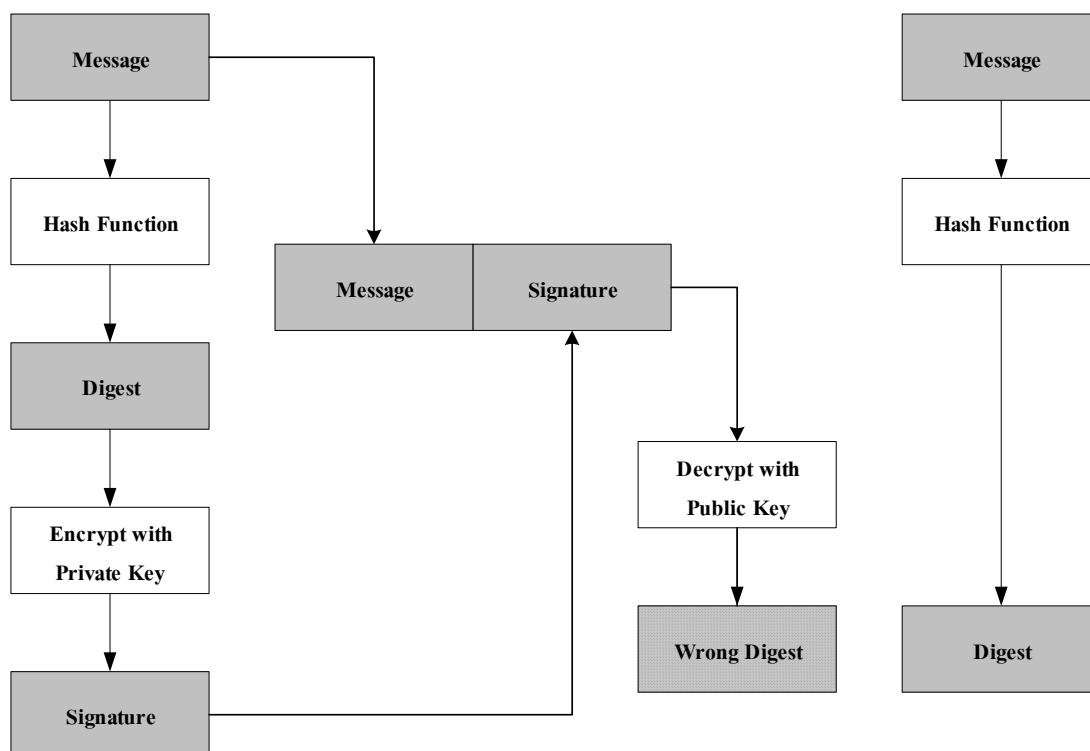
- สามารถยืนยันได้ว่าข้อมูลที่รับมานั้น ไม่มีการเปลี่ยนแปลงระหว่างการส่ง
- สามารถยืนยันได้ว่าข้อมูลนั้นได้รับการยืนยันจากผู้ส่งลายมือชื่อจริงๆ

การทำลายมือชื่อดิจิตอลนั้นทำได้โดยนำข้อความแรกเริ่มไปเข้าแฮชฟังก์ชันจะได้เป็นเมสเซจไจด์เพื่อเป็นการยืนยันความถูกต้องของข้อมูลก่อน จากนั้นจะนำเมสเซจไจด์ที่ได้ส่งไปเข้ารหัสกับคีย์ส่วนตัวของผู้ส่งเพื่อเป็นการยืนยันว่าเป็นเจ้าของเอกสารนั้นจริง และจะได้สิ่งที่เรียกว่าลายมือชื่อดิจิตอลออกมาส่งไปพร้อมกับข้อมูลด้วย ทางด้านรับนั้นจะเป็นวิธีการที่คล้ายกับด้านส่งโดยจะต้องเริ่มจากการหาเมสเซจไจด์ของข้อมูลที่ได้รับมาเก็บไว้ก่อน จากนั้นจะนำลายมือชื่อดิจิตอลที่ได้รับมาด้วย มาทำการถอดรหัสด้วยคีย์สาธารณะของผู้ส่ง ในขั้นตอนนี้จะสามารถยืนยันบุคคลผู้ส่งได้ เพราะถ้าหากผู้ที่ส่งลายมือชื่อไม่ได้เป็นบุคคลที่เราคาดว่าเป็นเจ้าของ ก็จะไม่สามารถถอดลายมือชื่อดิจิตอลได้ ถ้าหากการยืนยัน

บุคคลผู้ส่งสำเร็จแล้วจะได้รับเมสเซจไคเจสต์ของข้อมูลก่อนจะส่งออกมา ด้านรับจะต้องทำการตรวจสอบความถูกต้องของข้อมูลโดยการนำเมสเซจไคเจสต์ที่คำนวณได้ในตอนรับข้อมูล กับเมสเซจไคเจสต์ที่ได้หลังจากการถอดรหัสลายมือชื่อดิจิตอลออกมา นำมาเปรียบเทียบกัน ถ้าหากเมสเซจไคเจสต์ที่ได้ออกมามีค่าเท่ากันนั้นแสดงว่าข้อมูลที่ได้รับนั้นเป็นข้อมูลเดียวกันจากทางด้านส่ง และไม่มีการเปลี่ยนแปลงข้อมูลระหว่างการส่ง ขั้นตอนการส่ง และการรับของวิธีการนี้ แสดงไว้ในรูปที่ 4-4 โดยในกรณีที่มีการปลอมแปลงจะเป็นดังรูปที่ 4-5



รูปที่ 4-4 แสดงวิธีการทำลายมือชื่อโดยใช้แฮชฟังก์ชัน และคีย์ต่างๆ



รูปที่ 4-5 แสดงกรณีที่มีผู้แอบอ้าง

เมื่อมีผู้แอบอ้าง ผู้แอบอ้างไม่รู้คีย์ส่วนตัวของผู้ส่งจริงๆ จึงใช้คีย์ของตัวเอง ซึ่งไม่เข้าคู่กับคีย์สาธารณะทางฝั่งผู้รับ ทำให้ทางฝั่งผู้รับไม่สามารถถอดรหัสลายมือชื่อดิจิตอลได้ จึงรู้ว่าไม่ใช่ผู้ส่งตัวจริงเป็นคนส่ง

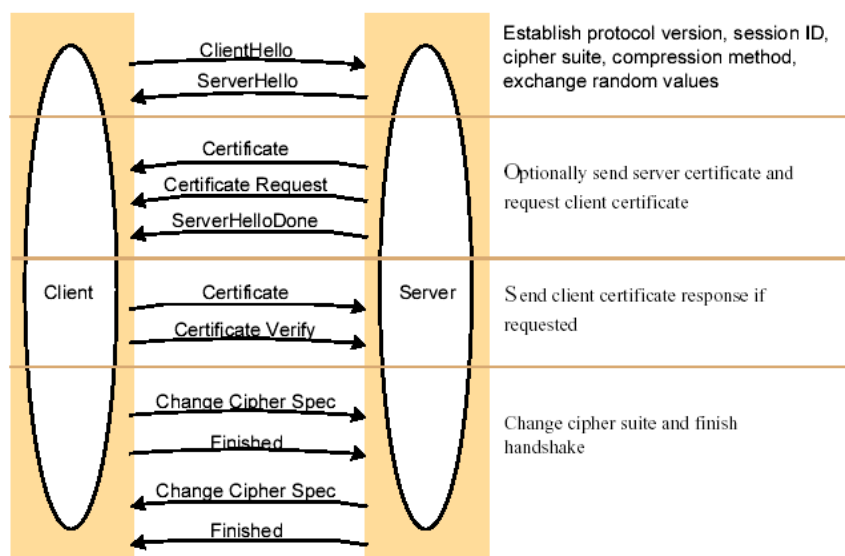
4.6 SSL Protocol

SSL Protocol สร้างความปลอดภัยให้กับแอปพลิเคชันที่ทำการติดต่อผ่านระบบเครือข่ายซึ่งมีรายละเอียดดังนี้

- กลไกในการที่แต่ละแอปพลิเคชันสามารถยืนยันตัวตนของแอปพลิเคชันอื่นได้
- เข้ารหัสข้อมูลที่ใช้ในการแลกเปลี่ยนระหว่างแอปพลิเคชัน

เมื่อ SSL Protocol ถูกใช้ ผู้รับการติดต่อจะทำการยืนยันตัวเองกับผู้เริ่มการติดต่อ ถ้าผู้รับการติดต่อร้องขอการติดต่อ ผู้เริ่มการติดต่อจะสามารถยืนยันตัวเองกับผู้รับการติดต่อได้ SSL connection จะเริ่มด้วยการ handshake ระหว่างแอปพลิเคชันจะแลกเปลี่ยนเอกสารสิทธิ์ (digital certificate) กัน ตกลงอัลกอริทึมในการเข้ารหัสที่จะใช้ และ สร้างคีย์ที่ใช้ในการเข้ารหัสสำหรับใช้ตลอดช่วงการติดต่อ

◆ SSL Protocol Handshake Phases



© Addison-Wesley Publishers 2000

รูปที่ 4-6 แสดงทรีเวย์แฮนด์เชค

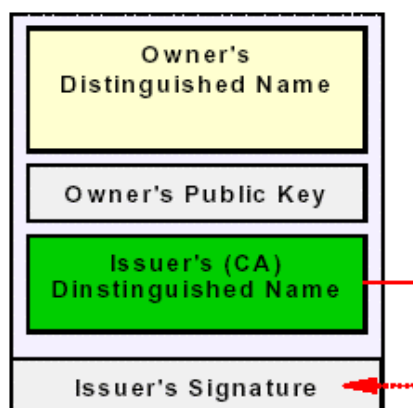
4.7 เอกสารสิทธิ์ (Digital Certificates)

ลักษณะของเอกสารสิทธิ์ดิจิทัล

เอกสารสิทธิ์เป็นเสมือนกับบัตรประจำตัวประชาชน ซึ่งจะบ่งบอกรายละเอียดของบุคคล เพื่อใช้ในการยืนยันตัวตน เราสามารถส่งเอกสารสิทธิ์ไปควบคู่กับลายมือชื่อดิจิทัลเพื่อใช้ในการยืนยันว่าเอกสารสิทธิ์นั้น ไม่มีการเปลี่ยนแปลง การสร้างเอกสารสิทธิ์ทำโดยผู้ใช้ทุกคนทำการขอเอกสารสิทธิ์กับองค์กรพิสูจน์สิทธิ์ (Certificate Authority : CA) โดยการส่งคีย์สาธารณะและข้อมูลตามที่องค์กรพิสูจน์สิทธิ์นั้นกำหนดไปและทำการขอเอกสารสิทธิ์มา การติดต่อต้องดำเนินการส่วนตัวหรือติดต่อผ่านระบบการพิสูจน์ตัวตนที่ปลอดภัย เราสามารถกำหนดสิ่งที่จะต้องใช้ในการสื่อสารได้ดังต่อไปนี้

1. ผู้ใช้ทุกคนสามารถค้นหาชื่อและคีย์สาธารณะของเจ้าของเอกสารสิทธิ์ได้
2. ผู้ใช้ทุกคนสามารถตรวจสอบได้ว่าเอกสารสิทธิ์มาจากองค์กรพิสูจน์สิทธิ์จริงๆ ไม่ได้ถูกปลอมแปลงมา
3. ผู้ใช้สามารถตรวจสอบได้ว่าเอกสารสิทธิ์นั้นหมดอายุหรือไม่
4. ผู้ที่สามารถอ้างและอัปเดต(update)เอกสารสิทธิ์ได้มีเพียงองค์กรมีอำนาจในการรับรองสิทธิ์เท่านั้น

5. ผู้ใช้ทุกคนสามารถตรวจสอบเอกสารสิทธิ์ได้เป็นประจำ



รูปที่ 4-7 แสดงส่วนประกอบต่างๆของเอกสารสิทธิ์

ความสำคัญของเอกสารสิทธิ์

ในการเข้ารหัสแบบคีย์ต่าง ๆ นั้นเราจะต้องมีการสร้างทั้งคีย์ส่วนตัวและคีย์สาธารณะ ซึ่งโดยทั่วไปการสร้างคีย์จะทำโดยโปรแกรมที่จะใช้คีย์นั้น เช่น โปรแกรมเว็บเบราว์เซอร์หรือโปรแกรมติดต่ออิเล็กทรอนิกส์เมลล์ หลังจากที่เราสร้างคีย์ทั้งสองเรียบร้อยแล้วการเก็บรักษาคีย์เป็นเรื่องสำคัญ เราจะต้องเก็บรักษาคีย์ส่วนตัวไว้ให้ดีอย่าให้ใครแอบมาเห็นหรือขโมยไปได้ จากนั้นจะเป็นการตัดสินใจว่าจะทำการแจกจ่ายคีย์สาธารณะของเราไปสู่ผู้อื่นด้วยวิธีใด เช่นการแจกคีย์โดยส่งอิเล็กทรอนิกส์เมลล์ไปให้เพื่อนหรือบุคคลที่ติดต่อกับเรา แต่วิธีนี้เราอาจส่งคีย์ไปให้ไม่ได้ครบทุกคน และยังคงเป็นภาระการจัดส่งคีย์ให้กับบุคคลใหม่ๆที่ต้องการติดต่อด้วย นอกจากนี้ยังไม่สามารถทำให้ผู้รับมั่นใจได้ว่าคีย์ที่ส่งไปนั้นเป็นคีย์ของเราจริงๆ เนื่องจากอาจมีผู้อื่นแอบสร้างคีย์โดยใช้ชื่อเราและแอบอ้างส่งคีย์ดังกล่าวให้กับผู้อื่นเพื่อให้เข้าใจว่าเป็นคีย์ของเราได้

วิธีที่ดีกว่าและใช้อยู่ในปัจจุบันก็คือการใช้ระบบแจกจ่ายคีย์ที่เชื่อถือได้โดยจะมีองค์กรที่ทำหน้าที่เฉพาะเป็นองค์กรที่สาม(Third Party) ในการรับรองและระงับการรับรองคีย์ที่เรียกว่าองค์กรพิสูจน์สิทธิ์(Certificate Authority - CA) โดยองค์กรพิสูจน์สิทธิ์นี้จะตรวจสอบคีย์สาธารณะของเราด้วยหลักฐานว่าคีย์ของเรานั้นๆเป็นของจริง พร้อมทั้งตรวจสอบข้อมูลส่วนตัวของเรา(ข้อมูลที่ตรวจสอบจะมากน้อยแค่ไหนขึ้นอยู่กับระดับชั้นของการรับรอง) เมื่อผู้อื่นได้รับคีย์ของเราก็สามารถที่จะตรวจสอบกับผู้ออกเอกสารสิทธิ์นี้ว่าคีย์ที่ได้รับเป็นของจริงหรือไม่ ซึ่งตัวเอกสารสิทธิ์นี้จะเปรียบเสมือนบัตรประชาชนดิจิทัลของเราที่ใช้บอกได้ว่าเราเป็นบุคคลที่อ้างจริงๆในระบบเครือข่ายหรือการส่งข้อมูลทางอิเล็กทรอนิกส์

ในปัจจุบันบริษัทที่ออกเอกสารสิทธิ์ดิจิทัล(Digital Certificate) คือบริษัท Verisign , Cybertrust , Global Sign และ Nortel โดยในเอกสารสิทธิ์ดิจิทัลจะประกอบด้วยข้อมูลต่างๆ ได้แก่ ชื่อของผู้ถือเอกสารสิทธิ์ ชื่อของบริษัทผู้ออกเอกสารสิทธิ์ คีย์สาธารณะของผู้ถือเอกสารสิทธิ์ วันหมดอายุของผู้ถือ

เอกสารสิทธิ์(โดยทั่วไปจะกำหนดระยะเวลา 6 เดือนหรือ 1 ปี) ระดับชั้นของเอกสารสิทธิ์ และเลขหมายของตัวเอกสารสิทธิ์ดิจิทัล

เอกสารสิทธิ์ดิจิทัลแบ่งออกได้เป็นสี่ระดับชั้นตามระดับการตรวจสอบข้อมูลของเจ้าของเอกสารสิทธิ์

1. ระดับที่หนึ่ง เป็นชั้นที่ออกเอกสารสิทธิ์ได้ง่ายที่สุดเนื่องจากมีการตรวจสอบน้อยที่สุด โดยจะตรวจแค่ชื่อผู้ถือเอกสารสิทธิ์ และที่อยู่อิเล็กทรอนิกส์เมลล์(e-mail address) ว่าถูกต้องจริงเท่านั้น
2. ระดับชั้นที่สอง จะตรวจสอบเลขประจำตัวประชาชน เลขประจำตัวของระบบสวัสดิการหรือประกันสังคม(social security number) และวันเดือนปีเกิด
3. ระดับชั้นที่สาม จะมีการตรวจสอบเพิ่มเติมเกี่ยวกับประวัติการใช้เครดิต และการชำระเงิน
4. ระดับชั้นที่สี่ ยังไม่มีการออกมาเป็นมาตรฐานอย่างแน่ชัด แต่จะเป็นการตรวจสอบข้อมูลเพิ่มเติมเกี่ยวกับตำแหน่งงานในองค์กรด้วย

ในการขอเอกสารสิทธิ์นั้นจะต้องกระทำการบนกระบวนการที่ปลอดภัย ซึ่งในปัจจุบันมี 2 วิธีคือ

1. การขอเอกสารสิทธิ์ผ่านโปรแกรมประเภทบราวเซอร์ เช่น อินเทอร์เน็ตเอ็กซ์พลอเรอร์, เนสเคปท์ เป็นต้น โดยผู้ใช้เข้าไปยังโฮสต์ที่ให้บริการการขอเอกสารสิทธิ์หรือเว็บไซต์ที่เปิดให้บริการดังกล่าวอยู่ ตัวโปรแกรมประเภทบราวเซอร์จะทำการสร้างคีย์ คู่คีย์ส่วนตัวจะเก็บไว้ที่เครื่องของเรา จากนั้นจะส่งคีย์สาธารณะและข้อมูลส่วนตัวของเราไปยังโฮสต์หรือเซิร์ฟเวอร์ที่เป็นขององค์กรพิสูจน์ จากนั้นองค์กรพิสูจน์สิทธิ์จะทำการรับรองข้อมูลแล้วจึงส่งเอกสารสิทธิ์กลับมาที่เครื่องของเรา
2. การขอเอกสารสิทธิ์อีกรูปแบบหนึ่งคือ การส่งเอกสารสิทธิ์ที่ไม่ผ่านระบบเครือข่าย กล่าวคือ ผู้ขอต้องไปทำการขอที่สำนักงานขององค์กรพิสูจน์สิทธิ์โดยตรง โดยทำเรื่องของเอกสารสิทธิ์และกรอกข้อมูลส่วนตัว องค์กรพิสูจน์สิทธิ์จะทำการรับรองและบันทึกข้อมูลของผู้ขอแล้วทำการส่งเอกสารสิทธิ์พร้อมทั้งคีย์ส่วนตัวให้กับผู้ขอในรูปแบบของไฟล์ในแผ่นดิสก์ให้ผู้ขอนำไปบันทึกในเครื่องของตนเองต่อไป

บริการพิสูจน์สิทธิ์แบบ X.509 (X.509 Authentication Service)

ระบบ X.509 เป็นระบบพิสูจน์สิทธิ์ที่สำคัญมากในระบบเครือข่าย โดย X.509 เป็นอนุกรมย่อยของ X.500 ซึ่งกำหนดมาตรฐาน ITU-T โดยขณะที่ X.500 เป็นตัวกำหนดโครงสร้างในลักษณะที่เป็นไคเรกทอรีหรือโครงสร้างนั้น X.509 จะทำหน้าที่ในการพิสูจน์สิทธิ์ให้กับส่วนต่าง ๆ ของไคเรกทอรีนั้น สำหรับรูปแบบการใช้งานจะเน้นไปที่การพิสูจน์บุคคล เพื่อยืนยันการติดต่อเป็นสำคัญ

การทำงานของ X.509 จะมีโครงสร้างการทำงานที่เป็นไคเรกทอรี โดยในที่นี้ไคเรกทอรี

จะทำหน้าที่เป็นที่เก็บข้อมูลที่ใช้ในการยืนยัน ซึ่งโดยทั่วไปจะอยู่ในรูปของเอกสารสิทธิ์ซึ่งในเอกสารสิทธิ์จะบรรจุคีย์สาธารณะของผู้ใช้ที่เข้ารหัสโดยคีย์ส่วนตัวขององค์กรที่จ่ายใบเอกสารสิทธิ์มาให้ สำหรับการดำเนินงานของ X.509 นั้นจะมีขอบเขตการนำไปใช้งานที่กว้างขวางมาก เช่น ใช้ในการทำ Mail Security ใช้ในการทำ IP Security ใช้ในการทำ Web Security หรือหากจะกล่าวถึง เมื่อใดที่ต้องการพิสูจน์บุคคลหรือยืนยันเครื่องคอมพิวเตอร์แล้ว ก็มักจะอยู่ในขอบข่ายการทำงานของ X.509 เสมอ

X.509 ได้ถูกนำเสนอเมื่อปี 1988 จากนั้นได้ผ่านการปรับปรุงเป็นลำดับขั้น ในประเด็นต่าง ๆ รวมทั้งเรื่องความปลอดภัยด้วย จากนั้นก็ได้ออกมาเป็นข้อเสนอที่ปรับปรุงแล้วในปี 1993 และปรับปรุงอีกครั้งในปี 1995 โดยการทำงานของ X.509 จะใช้การเข้ารหัสแบบคีย์สาธารณะแล้วใช้มาตรฐานลายมือชื่อดิจิทัลในการรับรองข้อมูล สำหรับอัลกอริทึมนั้น ไม่ได้ระบุแน่นอนโดยสามารถเลือกใช้ได้หลายตัวแต่ที่แนะนำคือ RSA

รูปแบบทั่วไปของเอกสารสิทธิ์

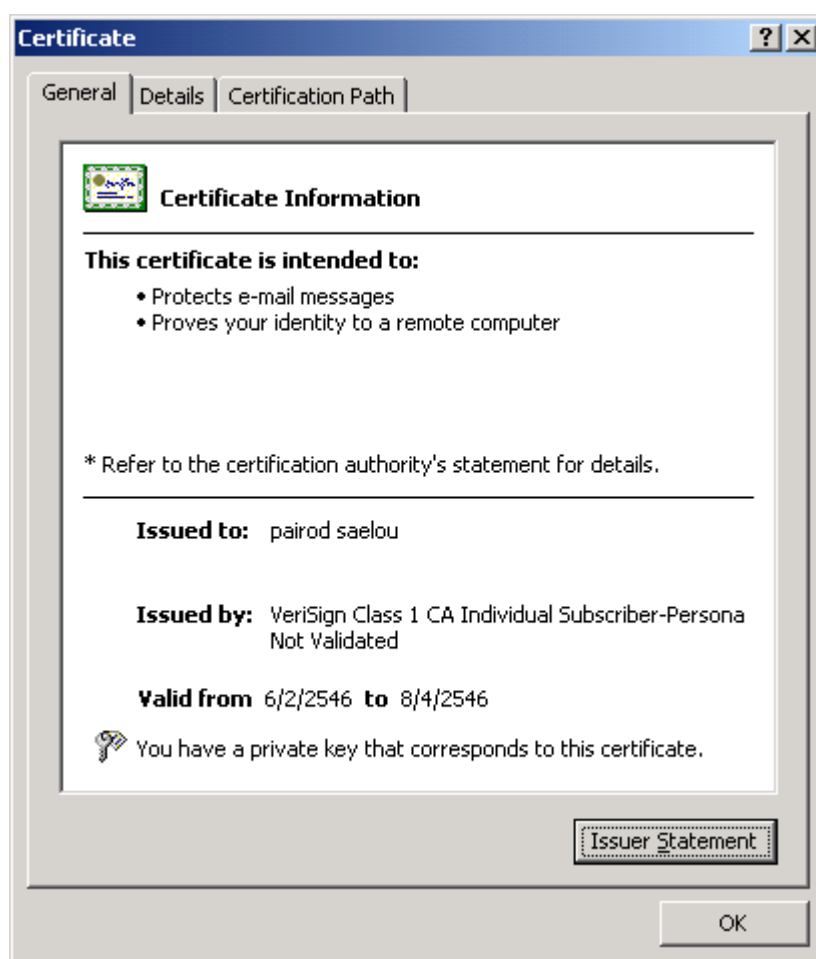
- เวอร์ชัน (Version) แสดงหมายเลขเวอร์ชัน เพราะในแต่ละเวอร์ชันจะมีรูปแบบของข้อมูลที่ไม่เหมือนกันก็ได้ โดยปกติจะเป็นเวอร์ชัน 1 แต่หากในเอกสารสิทธิ์มีการใช้
- หมายเลขลำดับ (Serial Number) เป็นเลขจำนวนเต็ม โดยจะต้องไม่ซ้ำกันในองค์กรที่ออกเอกสารสิทธิ์ โดยเลขนี้จะเป็นเลขที่จะใช้อ้างอิงแต่ละเอกสารสิทธิ์ที่สร้างขึ้น
- อัลกอริทึมที่ใช้สร้าง (Signature Algorithm Identifier) เป็นฟิลด์ที่ระบุอัลกอริทึมที่ใช้ในการสร้างเอกสารสิทธิ์
- ชื่อผู้ออกเอกสารสิทธิ์ (Issue Name) เป็นชื่อขององค์กรที่ออกเอกสารสิทธิ์
- ช่วงเวลาที่รับรองเอกสารสิทธิ์ (Period of Validity) เป็นตัวบอกว่า ให้ใช้เอกสารสิทธิ์นี้ตั้งแต่วันที่เท่าไรและสิ้นสุดวันที่เท่าไร
- ชื่อเจ้าของเอกสารสิทธิ์ (Subject Name) เป็นชื่อของบุคคลที่เอกสารสิทธิ์ใบนี้อ้างถึงหรือแทนตัวบุคคลนั้น
- ข้อมูลของคีย์สาธารณะ (Subject's Public Key Information) เป็นฟิลด์ที่เก็บคีย์สาธารณะและระบุถึงอัลกอริทึมที่ใช้กับคีย์นี้ขึ้นมา รวมถึงพารามิเตอร์อื่น ๆ ด้วย
- ตัวระบุผู้ออกเอกสารสิทธิ์ (Issuer Unique Identifier) เป็นฟิลด์ที่ใช้อ้างอิงถึงองค์กรที่ออกเอกสารสิทธิ์ ในกรณีที่มีชื่อ X.500 มีการนำไปใช้กับส่วนอื่น ๆ
- ตัวระบุผู้ขอเอกสารสิทธิ์ (Subject Unique Identifier) เป็นฟิลด์ที่ใช้ในการระบุถึงตัวบุคคลที่เป็นเจ้าของเอกสารสิทธิ์ ในกรณีที่มีชื่อ X.500 มีการนำไปใช้กับส่วนอื่น ๆ
- ส่วนขยาย (Extension) เป็นกลุ่มของฟิลด์ที่เพิ่มเติมข้อมูลอื่น ๆ เข้ามาด้วย
- ลายมือชื่อ (Signature) จะบรรจุเมสเสจไดเจสต์ของข้อมูลในทุกฟิลด์ที่เข้ารหัสด้วยคีย์ส่วนตัวขององค์กรพิสูจน์สิทธิ์เพื่อเป็นการยืนยันว่า เอกสารสิทธิ์นี้สร้างมาจากองค์กรดังกล่าวจริง ๆ โดยจะมีข้อมูลที่ระบุวิธีการแฮชและวิธีการเข้ารหัสด้วย

ในการใช้งานเอกสารสิทธิ์จะมีช่วงเวลาใช้งานที่จำกัดแน่นอน ดังนั้นหากผู้ใช้ต้องการใช้เอกสารสิทธิ์ต่อไป ก็ต้องขอต่ออายุเอกสารสิทธิ์ก่อนที่จะหมดอายุ แต่หากจะมีการหมดอายุโดยที่ไม่ขอต่อหรือมีการเลิกใช้เอกสารสิทธิ์อาจจะเนื่องมาจากพนักงานลาออก หรืออาจจะเนื่องจากเอกสารสิทธิ์นี้ไม่ปลอดภัยแล้วก็ต้องทำการเรียกคืน (Revoke) และองค์กรพิสูจน์สิทธิ์จะต้องมีการจัดทำรายการเอกสารสิทธิ์ที่ถูกเรียกคืน (Certificate Revocation List - CRL) ซึ่งจะเก็บไว้ในไคลเอนต์และรับรองโดยองค์กรพิสูจน์สิทธิ์ ซึ่งผู้ที่ต้องการตรวจสอบเอกสารสิทธิ์ว่าเป็นเอกสารสิทธิ์ที่ไม่ใช้งานแล้วหรือไม่ ก็ต้องขอรายการเอกสารสิทธิ์ที่ถูกเรียกคืนไปตรวจสอบ

และเนื่องจากเอกสารสิทธิ์ไม่สามารถปลอมได้ ดังนั้นการเก็บเอกสารสิทธิ์ไว้ที่องค์กรพิสูจน์สิทธิ์จึงไม่ต้องมีกลไกพิเศษมาป้องกันแต่อย่างใด กล่าวคือผู้ใช้คนใดที่เป็นสมาชิกขององค์กรพิสูจน์สิทธิ์ก็สามารถเข้าถึงเอกสารสิทธิ์ของผู้ใช้คนอื่น ๆ ได้ทุกคน โดยเอกสารสิทธิ์จะเก็บอยู่ในไฟล์เพียงไฟล์เดียวที่มีขนาดเล็ก นอกจากจะสามารถขอเอกสารสิทธิ์จากองค์กรพิสูจน์สิทธิ์แล้วผู้ใช้อย่างยังสามารถส่งเอกสารสิทธิ์ไปให้กันเองได้อีกด้วย โดยผ่านทางสื่อต่าง ๆ เช่น จดหมายอิเล็กทรอนิกส์, ส่งผ่านแผ่นดิสก์เก็ต เป็นต้น

อย่างไรก็ตาม เนื่องจากระบบเครือข่ายในปัจจุบันมีขนาดใหญ่โตกว้างขวางมาก และการติดต่อสื่อสารก็ไม่ได้มีลักษณะเฉพาะกลุ่มอีกแล้ว ดังนั้นการที่จะให้ผู้ใช้ทุกคนมาใช้เอกสารสิทธิ์ที่รับรองโดยองค์กรพิสูจน์สิทธิ์เดียวกันทั้งหมดก็อาจเป็นเรื่องยาก หากผู้ใช้ 2 คนใช้เอกสารสิทธิ์ที่รับรองจากองค์กรพิสูจน์สิทธิ์คนละแห่งก็จะไม่สามารถตรวจสอบเอกสารสิทธิ์ของอีกฝ่ายได้ว่าเป็นฉบับจริงหรือไม่ ซึ่งในกรณีเช่นนี้ ก็อาจจะใช้วิธีสำเนาที่สาธารณะขององค์กรพิสูจน์สิทธิ์ของผู้ใช้อีกคนหนึ่งมาทำการตรวจสอบเองก็สามารถทำได้ เช่น กำหนดให้มี CA-A และ CA-B โดยให้บริการกับผู้ใช้ A และ B แต่เนื่องจากในครั้งแรกที่ A สำเนาที่สาธารณะของ CA-B มานั้นอาจเกิดการปลอมแปลงได้ เพราะสิ่งที่เรามีอยู่ก็คือที่สาธารณะของ CA-A ของเรา แต่เอกสารสิทธิ์ของ CA-B ทำให้เราไม่สามารถตรวจสอบว่าเอกสารสิทธิ์ที่ได้รับมานั้นเป็นฉบับที่ถูกต้องหรือไม่ ดังนั้นวิธีดังกล่าวจึงถือว่า ไม่มีความปลอดภัยเพียงพอ

สำหรับอีกวิธีการอีกแบบ คือให้ CA-A เก็บเอกสารสิทธิ์ของ CA-B เอาไว้ด้วยและ CA-B ก็เก็บเอกสารสิทธิ์ของ CA-A เอาไว้เช่นกัน ด้วยวิธีนี้เราก็สามารถให้องค์กรพิสูจน์สิทธิ์ตรวจสอบเอกสารสิทธิ์ได้ว่าเอกสารสิทธิ์นั้นจะรับรองจาก CA-A หรือ CA-B ก็ตาม เช่น ผู้ใช้ A ต้องการตรวจสอบเอกสารสิทธิ์ที่รับรองจาก CA-A ก็สามารถทำได้เลยเพราะรู้ที่สาธารณะของ CA-A อยู่แล้วเนื่องจากเป็นสมาชิก CA-A และหากผู้ใช้ A ต้องการตรวจสอบเอกสารสิทธิ์ที่รับรองโดย CA-B ผู้ใช้ A ก็ขอเอกสารสิทธิ์ของ CA-B จาก CA-A โดยเอกสารสิทธิ์ดังกล่าวจะรับรองโดย CA-A ดังนั้นจึงแน่ใจได้ว่าเอกสารสิทธิ์ของ CA-B ที่ได้รับนั้นเป็นของจริงและที่สาธารณะของ CA-B ก็เป็นของจริง



รูปที่ 4-8 แสดงเอกสารสิทธิ์ที่ตรวจสอบโดยบราวเซอร์

จากนั้นจึงนำเอาคีย์สาธารณะของ CA-B ไปตรวจสอบเอกสารสิทธิ์อีกทีก็จะทราบได้ว่าเอกสารสิทธิ์นั้นเป็นของจริงหรือไม่ และนอกเหนือจาก CA-A และ CA-B แล้วการเชื่อถือ(Trust)กันเช่นนี้ยังสามารถกระทำกับองค์กรพิสูจน์สิทธิ์อื่นๆไปเรื่อยๆ อย่างไรก็ตามหากองค์กรพิสูจน์สิทธิ์มีเป็นจำนวนมากแล้ว ก็มีความจำเป็นที่จะต้องจัดโครงสร้างการเชื่อถือกันขององค์กรพิสูจน์สิทธิ์ให้เป็นระบบ ไม่เช่นนั้นก็อาจมีการเชื่อถือกันแบบยุ่งเหยิงและทำให้การทำงานเป็นไปอย่างไม่มีประสิทธิภาพได้ ซึ่งมาตรฐาน X.509 ก็ได้แนะนำให้มีการใช้ระบบเชื่อถือกันในรูปของความสัมพันธ์แบบระดับชั้น(Hierarchical)

องค์กรพิสูจน์สิทธิ์

เอกสารสิทธิ์จะถูกออกโดยองค์กรพิสูจน์สิทธิ์ที่ซึ่งเป็นองค์กร(บุคคลที่สาม)ที่เชื่อถือได้ เมื่อ องค์กรพิสูจน์สิทธิ์สร้างเอกสารสิทธิ์แล้ว จะทำการเข้ารหัสด้วยคีย์ส่วนตัวขององค์กรพิสูจน์สิทธิ์นั้น แล้วจะทำการส่งไปให้กับผู้ที่ขอเอกสารสิทธิ์นั้น

โดยผู้ขอเอกสารสิทธิ์จะยื่น ยัน ตัวขององค์กรพิสูจน์สิทธิ์นั้น ด้วยคีย์สาธารณะซึ่งถูกออกด้วย high-level certificate authority ซึ่งมีความน่าเชื่อถือกว่า

4.8 การอิมพลีเมนต์ Security ในเว็บลอจิก

เว็บลอจิกจะมีส่วนของ authentication, authorization และการเข้ารหัสให้บริการเพื่อที่จะป้องกันความปลอดภัยในทรัพยากรของคุณ แต่อย่างไรก็ดีวิธีการเหล่านี้ก็ยังไม่สามารถแก้ปัญหาในกรณีที่มีคนค้นพบช่องโหว่ หรือ จุดอ่อน ในสภาพแวดล้อมการดีพลอย (deployment environment) ของคุณได้

ทางที่ดีคือ หลังจากที่คุณดีพลอยเว็บลอจิกเซิร์ฟเวอร์แล้ว คุณควรจะให้ผู้ที่เชี่ยวชาญในด้านความปลอดภัยมาตรวจสอบ และแนะนำในการปรับปรุงให้มีความปลอดภัยยิ่งขึ้น นอกจากนี้คุณอาจจะติดตามวารสารต่างๆ ที่เกี่ยวกับความปลอดภัย ,ตรวจสอบเรื่องของบั๊กและคอยปรับปรุง service pack ต่างๆ

4.8.1 Security Realms

Security Realms ประกอบไปด้วยกลไกในการป้องกันทรัพยากรของเว็บลอจิกเซิร์ฟเวอร์โดย resource ของเว็บลอจิกเซิร์ฟเวอร์จะถูกป้องกันภายใต้ Security realms เพียงอันเดียวเท่านั้น และโดยนโยบายหนึ่งเดียวของ Security realms เมื่อ user ต้องการที่จะเข้าถึงทรัพยากรใดๆที่เป็นของ realms นั้นๆ เซิร์ฟเวอร์จะพยายามที่จะพิสูจน์ตัวตนของผู้ใช้นั้น

4.8.2 ผู้ใช้

คือเอนิตี้ที่มาเรียกใช้ เว็บลอจิกเซิร์ฟเวอร์เช่นแอปพลิเคชัน end users หรือเว็บลอจิกเซิร์ฟเวอร์ด้วยกันเอง

เมื่อผู้ใช้ต้องการที่จะเข้าถึงเว็บลอจิกเซิร์ฟเวอร์ ผู้ใช้นั้นจะต้องแสดงหลักฐาน(เช่น password หรือ digital certificate) ผ่าน JAAS เพื่อที่จะ authentication ต่อ security realm เมื่อเว็บลอจิกเซิร์ฟเวอร์สามารถยืนยันผู้ใช้นั้นได้จะทำการเข้าไปมีส่วนร่วมกับผู้ไปด้วย thread ที่ทำการ execute code ของผู้ใช้ แต่ก่อนที่ thread จะเริ่มทำการ execute code เซิร์ฟเวอร์จะทำการตรวจสอบบทบาท และสิทธิของผู้ใช้อีกทีเพื่อยืนยันว่าผู้ใช้สามารถทำได้

การระบุผู้ใช้ในเว็บลอจิกนั้น คุณสามารถใช้การระบุรหัสผ่านสำหรับผู้ใช้นั้นๆ โดยเว็บลอจิก จะทำการแฮชทุกรหัสผ่าน หลังจากได้รับการร้องขอรหัสผ่านจากไคลเอนต์จะถูกแฮชและ เว็บเซิร์ฟเวอร์จะทำการเปรียบเทียบกับรหัสผ่านที่ถูกแฮชแล้ว

4.8.3 Group

Group คือ กลุ่มของผู้ใช้ การจัดการกับ group นั้นมีประสิทธิภาพมากกว่าการจัดการเป็นทีละผู้ใช้ยกตัวอย่างเช่น administrator สามารถกำหนดสิทธิ (permission) สำหรับ 50 ผู้ใช้ได้ในครั้งเดียวโดยการกำหนดบทบาท และสิทธิให้กับ group

4.8.4 Access Control Mechanisms

กลไก 2 แบบที่มีอยู่ในเว็บล็อกิเชิร์ฟเวอร์ซึ่งทำการด้วยกันเพื่อที่จะควบคุม และป้องกันการเข้าถึงทรัพยากร คือ Security Policies และ Roles

SSL Protocol กำหนดคุณสมบัติของ security ดังนี้

- Server authentication – เว็บล็อกิเชิร์ฟเวอร์ใช้ เอกสารสิทธิ์ของมันเพื่อที่จะใช้ในการยืนยันกับไคลเอนต์
- Client Identify Verification – ไคลเอนต์ก็จะทำการยืนยันตัวเองกับเว็บล็อกิเชิร์ฟเวอร์โดยใช้เอกสารสิทธิ์ของมันเอง โดยเซิร์ฟเวอร์จะทำการตรวจสอบเอกสารสิทธิ์ของไคลเอนต์ และ เริ่ม SSL connection ถ้าเอกสารสิทธิ์ได้รับการยืนยันแล้วว่าถูกต้อง วิธีนี้เรียกว่า two-way SSL เนื่องจากผู้ใช้มีได้หลายคนดังนั้น ไคลเอนต์ต้องใช้ทั้ง username และรหัสผ่าน(or เอกสารสิทธิ์) ในการ authentication และ authorization
- Confidentiality – ทั้งการร้องขอของไคลเอนต์และการตอบสนองของเซิร์ฟเวอร์จะถูกเข้ารหัสเพื่อที่จะทำให้ การแลกเปลี่ยนข้อมูลเป็นส่วนตัวมากขึ้นตลอดเส้นทางในระบบเครือข่าย
- Data Integrity – ข้อมูลที่ส่งระหว่างไคลเอนต์กับเซิร์ฟเวอร์จะถูกป้องกันจากกลุ่มบุคคลที่ 3

4.8.5 Authentication Mechanisms

ผู้ใช้งานจะต้องทำการยืนยันตัวเองทุกครั้งที่ต้องการ ผู้ใช้ต้องการที่จะเข้าถึงทรัพยากรที่ถูกป้องกันไว้ โดยเว็บล็อกิเชิร์ฟเวอร์ด้วยเหตุนี้เอง ผู้ใช้งานต้องมีหนังสือแนะนำตัว(username/password หรือเอกสารสิทธิ์) ต่อ เว็บล็อกิเชิร์ฟเวอร์ ซึ่งเว็บล็อกิเชิร์ฟเวอร์จะมีกลไกในการยืนยันตัวตน 2 แบบ คือ

- Username/Password authentication – user ID และรหัสผ่านจากไคลเอนต์จะถูกส่งไปยังเซิร์ฟเวอร์ เพื่อที่จะทำการตรวจสอบข้อมูลที่มี และถ้าถูกต้องก็จะอนุญาตให้เข้าถึงทรัพยากรได้ SSL(หรือ HTTPS) โพรโตคอลจะสามารถถูกใช้เพื่อเพิ่มระดับของความปลอดภัยในการส่ง username และรหัสผ่านเนื่องจากโพรโตคอลนี้ จะทำการเข้ารหัสข้อมูลที่ส่งระหว่างไคลเอนต์และเซิร์ฟเวอร์
- Certificate authentication – เมื่อ SSL หรือ HTTPS ผู้ใช้เริ่มต้นการร้องขอ เว็บล็อกิเชิร์ฟเวอร์จะตอบกลับโดยส่งเอกสารสิทธิ์ ของมันไปให้ไคลเอนต์ โดยไคลเอนต์จะทำการตรวจสอบ แล้วส่งเอกสารสิทธิ์ของมัน เซิร์ฟเวอร์จะทำการตรวจสอบเอกสารสิทธิ์ของไคลเอนต์โดยใช้ CertAuthenticator class ของมันทำการดึงเอาข้อมูลออกมาจากเอกสารสิทธิ์ของไคลเอนต์เพื่อตรวจสอบว่าเป็นของผู้ใช้คนไหน แล้วทำการยืนยันผู้ใช้จาก security realm การทำ mutual authentication นี้มีประโยชน์ในกรณีที่ เราต้องการจะจำกัดผู้ใช้ให้อยู่ในวงผู้ใช้ที่เราเชื่อถือได้เท่านั้น